Sicurezza dei Sistemi Informativi

Appello d'Esame del 30 Gennaio 2024

Anno Accademico 2023-2024

Politecnico di Torino — Docente: Prof. Cataldo Basile

2024-01-30

1 Testo Ufficiale dell'Esame

Domanda 1: Domande a Selezione Multipla

Scegli le affermazioni corrette dalla lista (risposte corrette danno punteggio positivo, risposte errate danno punteggio negativo):

a. Un NIDS è uno scanner di rete che identifica vulnerabilità note.

b. Un IPS può permettere di velocizzare ed automatizzare la risposta alle intrusioni rilevate.

c. Gli honeypot sono strumenti che servono ad attirare gli attaccanti simulando il fatto che le risorse siano più facili da attaccare per aumentare il loro interesse e studiarne le tecniche.

d. Un HIDS può verificare che alcuni file critici non vengano modificati e analizzare quello che riportano i log dei sistemi informativi.

e. Un SOC dovrebbe includere anche personale che si occupa dell'analisi del cybercrime e threat intelligence per mantenere aggiornata l'analisi dei rischi.

f. Le persone che lavorano in un SOC non dovrebbero occuparsi di vulnerability management e patch management.

g. I dati relativi allo stato di salute e alla razza/origine etnica sono considerati dal GDPR dati di categoria particolare (sensibili) e richiedono misure di protezione rafforzate.

h. A parità di livello di sicurezza equivalente, la crittografia a curve ellittiche richiede chiavi di dimensione nettamente inferiore rispetto a RSA.

Domanda 2: Esercizio di Progettazione Rete e Filtraggio Firewall

Un'azienda possiede una rete complessa suddivisa nelle seguenti sottoreti:

- Sottorete Amministrazione: `192.168.1.0/24`;
- Sottorete Sviluppo: `192.168.2.0/24`;
- Sottorete Ospiti: `192.168.3.0/24`;
- Sottorete DMZ: `192.168.129.0/24` (ospita server web e proxy di autenticazione).

Requisiti di sicurezza:

1. Nessuna rete interna (`.1`, `.2`, `.3`, `.129`) deve poter essere raggiunta direttamente dall'esterno (Internet).
2. Gli host della sottorete `.1` devono essere raggiungibili dalle sottoreti `.2` e `.3` solo per servizi approvati.
3. Gli utenti della sottorete Ospiti (`.3`) possono accedere a Internet solo previa autenticazione su Captive Portal/Proxy situato in DMZ (`.129`).
4. Gli host della sottorete Sviluppo (`.2`) possono accedere direttamente ad Internet via NAT ma non alla sottorete Amministrazione (`.1`) se non esplicitamente autorizzati.
5. Configurare la tabella delle regole per il firewall perimetrale e descrivere l'architettura applicata.

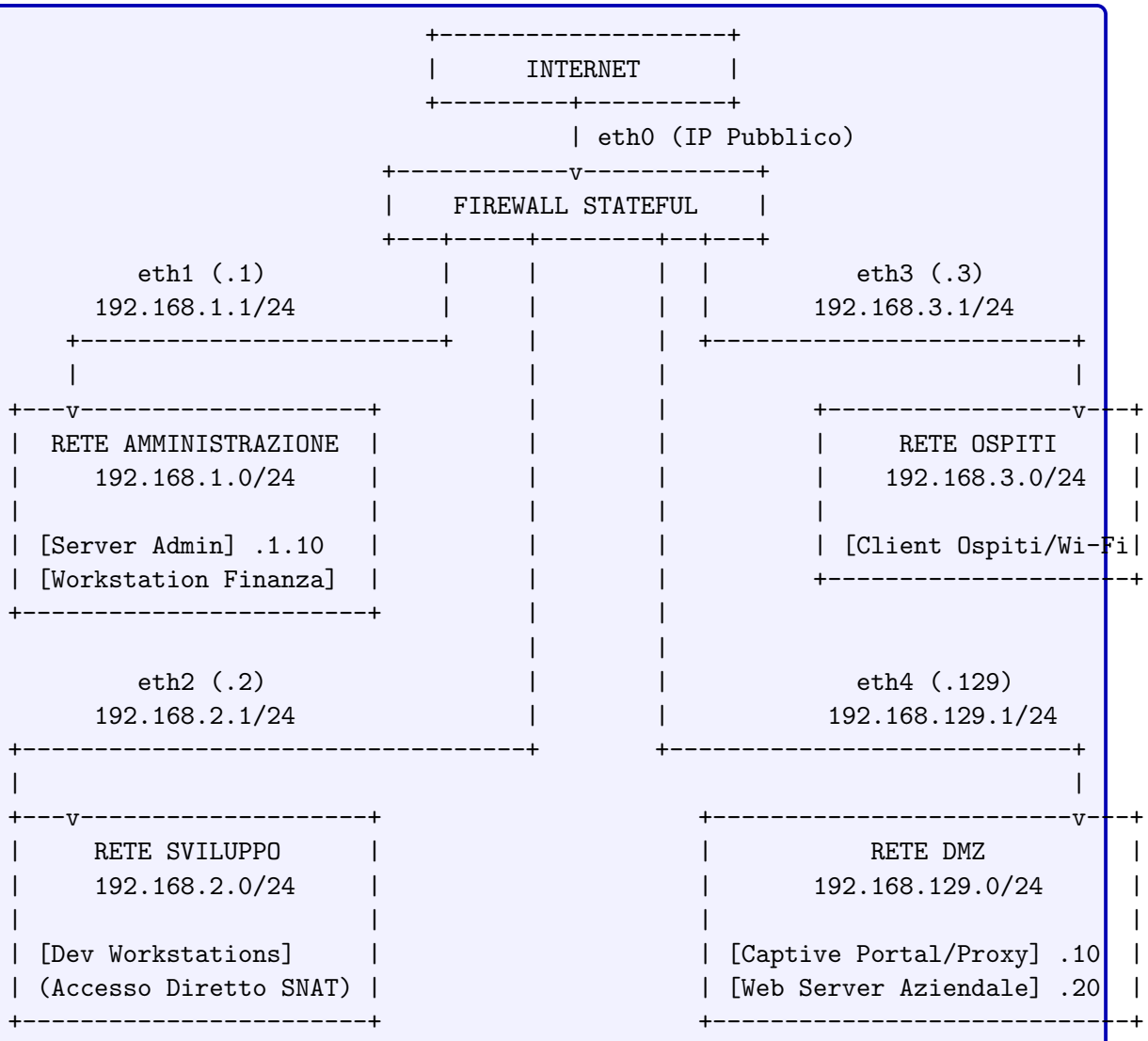
2 Soluzione Dettagliata e Guida Risolutiva

Soluzione Domanda 1: Valutazione Crocette

- **a. FALSA**: Un Network Intrusion Detection System (NIDS, come Snort o Suricata) analizza passivamente il traffico di rete in tempo reale alla ricerca di firme di attacco, anomalie o payload exploit; **non è uno scanner di vulnerabilità** (strumenti come Nessus, OpenVAS o Qualys che eseguono probing attivo per censire porte aperte e falle software non patchate).
- **b. VERA**: Un Intrusion Prevention System (IPS, conforme a NIST SP 800-94) è posizionato *in-line* sul flusso dati; al rilevamento di una minaccia esegue azioni automatiche e immediate di mitigazione (drop di pacchetti, invio di TCP RST, o istruzioni di blocco dinamico al firewall perimetrale), accelerando la risposta agli incidenti.
- **c. VERA**: Gli honeypot (sia *low-interaction* che *high-interaction*) emulano sistemi o servizi vulnerabili con il duplice obiettivo di distogliere l'attaccante dai sistemi di produzione critici e studiarne tattiche, tecniche e procedure (TTP secondo il framework MITRE ATT&CK).
- **d. VERA**: Un Host-based IDS (HIDS, es. Wazuh, OSSEC, Tripwire) installato a bordo dell'endpoint monitora l'integrità dei file di sistema (*File Integrity Monitoring - FIM*), ispeziona i log locali (syslog, Event Viewer) e controlla le chiamate a sistema per rilevare privilege escalation o rootkit.
- **e. VERA**: Un Security Operations Center (SOC) evoluto include specialisti di Cyber Threat Intelligence (CTI) per acquisire indicatori di compromissione (IoC) e feed di minaccia esterni, integrando l'analisi predittiva dei rischi e aggiornando le regole di correlazione del SIEM.
- **f. VERA**: Il principio organizzativo di separazione delle mansioni (*Separation of Duties*) prevede che il SOC si focalizzi sul monitoraggio, detection e incident handling, mentre l'attività operativa di patch deployment e vulnerability remediation competa ai team di IT Operations / System Administration (in accordo con NIST SP 800-40).
- **g. VERA**: L'Art. 9 del GDPR ("Trattamento di categorie particolari di dati personali") include esplicitamente i dati relativi alla salute, all'origine razziale o etnica, dati genetici e biometrici, imponendone il divieto generale di trattamento salvo consenso esplicito o stringenti eccezioni di legge.
- **h. VERA**: Secondo le raccomandazioni NIST SP 800-57 sui livelli di sicurezza computazionale equivalente, la crittografia a curve ellittiche (ECC) richiede chiavi drasticamente più corte: una chiave ECC da 256 bit garantisce una sicurezza equivalente a una chiave RSA da 3072 bit (128 bit di sicurezza simmetrica equivalente), con notevole risparmio di banda e computazione.

Soluzione Domanda 2: Architettura di Rete e Tabella Regole Firewall

Architettura Selezionata e Topologia Screened Subnet: La rete aziendale è suddivisa in quattro sottoreti fisicamente o logicamente separate (VLAN) collegate a un firewall stateful perimetrale multiporta:



Subnetting IP, Instradamento e Requisiti di Sicurezza:

- **Interfaccia `eth0` (Internet)**: Applica Source NAT (SNAT) per gli sviluppatori e per il Proxy degli ospiti. Nessuna connessione in ingresso da Internet può raggiungere direttamente le reti interne (`192.168.0.0/16`).
- **Amministrazione (`eth1`, `192.168.1.0/24`)**: Gateway `192.168.1.1`. Raggiungibile da Sviluppo e Ospiti solo per servizi esplicitamente autorizzati.
- **Sviluppo (`eth2`, `192.168.2.0/24`)**: Gateway `192.168.2.1`. Può accedere direttamente ad Internet con SNAT. Traffico verso Amministrazione bloccato di default.
- **Ospiti (`eth3`, `192.168.3.0/24`)**: Gateway `192.168.3.1`. Gli ospiti non hanno accesso diretto a Internet: possono contattare unicamente il Captive Portal / Proxy (`192.168.129.10`) sulle porte 80/443/8080. Il Proxy inoltra il traffico verso Internet solo previa autenticazione.
- **DMZ (`eth4`, `192.168.129.0/24`)**: Gateway `192.168.129.1`. Ospita i servizi perimetrali di mediazione e controllo.

Tabella Regole del Firewall (Default Policy: DROP):

ID	Dir	Src IP	Dst IP	Proto	Port	State
1	Any	Any	Any	Any	Any	ESTABLISHED, RELA
2	In/Fwd	192.168.3.0/24	192.168.129.10	TCP	80, 443, 8080	NEW
3	In/Fwd	192.168.129.10	Any (Internet)	TCP	80, 443	NEW
4	In/Fwd	192.168.2.0/24	Any (Internet)	TCP	80, 443	NEW

Alternative Implementation Note: Strutture Rust per State Table del Firewall

In Rust, una tabella di connessioni per packet filter ad altissimo throughput può essere implementata con:

- `dashmap::DashMap<FiveTuple, ConnectionRecord>`: Mappa concorrente partizionata a granularità fine che elimina il collo di bottiglia del singolo mutex globale per letture e scritture ad alta frequenza.
- `std::sync::atomic::AtomicU32`: Per contatori di pacchetti e byte per-flusso senza sincronizzazione bloccante.